Manual Chapter : Mitigating Denial of Service Attacks

Applies To:

Show Versions

Configuring a Simple Intranet

Configuring ISP Load Balancing

Routing Based on XML Content

Configuring nPath Routing

Configuring Layer 3 nPath Routing

Creating a Basic Web Site and E-commerce Configuration

Installing a BIG-IP System Without Changing the IP Network

Enabling IP Address Intelligence

Configuring Content Adaptation for HTTP Requests

Configuring Content Adaptation for HTTP Requests and Responses

Configuring HTTP Load Balancing with Source Address Affinity Persistence

Configuring HTTP Load Balancing with Cookie Persistence

Compressing HTTP Responses

Using Via Headers to Acquire Information About Intermediate Routers

Configuring the BIG-IP System as a Reverse Proxy Server

Load Balancing Passive Mode FTP Traffic

Load Balancing Passive Mode FTP Traffic with Data Channel Optimization

Configuring the BIG-IP System as a DHCP Relay Agent

Configuring the BIG-IP System for DHCP Renewal

Configuring a One-IP Network Topology

Configuring the BIG-IP System to Auto-Populate Pools

Implementing Health and Performance Monitoring

Preventing TCP Connection Requests From Being Dropped

Setting Connection Limits

Load Balancing to IPv6 Nodes

Mitigating Denial of Service Attacks

Implementing APM System Authentication

Configuring an SSL Intercept Explicit Proxy Mode

Configuring an Explicit HTTP Proxy Chain

Manipulating HTTPS Traffic by Using a Third-Party Device

Legal Notices

Mitigating Denial of Service Attacks

Overview: Mitigating Denial of Service and other attacks

The BIG-IP system contains several features that provide you with the ability to create a configuration that contributes to the security of your network. In particular, the BIG-IP system is in a unique position to mitigate some types of Denial of Service (DoS) attacks that try to consume system resources in order to deny service to the intended recipients.

The following features of the BIG-IP system help it resist many types of DoS attacks:

- The BIG-IP kernel has a mechanism built in to protect against SYN Flood attacks by limiting simultaneous connections, and tearing down connections that have unacknowledged SYN/ACK packets after some time period as passed. (A SYN/ACK packet is a packet that is sent as part of the TCP three-way handshake).
- BIG-IP system can handle tens of thousands of Layer 4 (L4) connections per second. It would take a very determined attack to affect either the BIG-IP system itself, or the site, if sufficient server resources and bandwidth are available.
- SYN floods, or Denial of Service (DoS) attacks, can consume all available memory. The BIG-IP system supports a large amount of memory to help it resist DoS attacks.

Denial of Service attacks and iRules

You can create BIG-IP iRules® to filter out malicious DoS attacks. After you identify a particular attack, you can write an iRule that discards packets containing the elements that identify the packet as malicious.

iRules for Code Red attacks

The BIG-IP system is able to filter out the Code Red attack by using an iRule to send the HTTP request to a dummy pool.

```
when HTTP_REQUEST {
  if {string tolower [HTTP::uri] contains "default.ida" } {
     discard
  } else {
     pool RealServerPool
}
```

iRules for Nimda attacks

The Nimda worm is designed to attack systems and applications based on the Microsoft Windows operating system.

```
when HTTP_REQUEST {
    set uri [string tolower [HTTP::uri]]
    if { ($uri contains "cmd.exe") or ($uri contains
          "root.exe") or ($uri contains "admin.dll") } {
         discard
    } else {
       pool ServerPool
  }
}
```

Common Denial of Service attacks

You might want to know how the BIG-IP system reacts to certain common attacks that are designed to deny service by breaking the service or the network devices. The following information lists the most common attacks, along with how the BIG-IP system functionality handles the attack.

Attack type	Description	Mitigation
SYN flood	A ***SYN flood*** is an attack against a system for the purpose of exhausting that system's resources. An attacker launching a SYN flood against a target system attempts to occupy all available resources used to establish TCP connections by sending multiple SYN segments containing incorrect IP addresses. Note that the term SYN refers to a type of connection state that occurs during establishment of a TCP/IP connection. More specifically, a SYN flood is designed to fill up a SYN queue. A SYN queue is a set of connections stored in the connection table in the SYN-RECEIVED state, as part of the standard three-way TCP handshake. A SYN queue can hold a specified maximum number of connections in the SYN-RECEIVED state. Connections in the SYN-RECEIVED state are considered to be half-open and waiting for an acknowledgment from the client. When a SYN flood causes the maximum number of allowed connections in the SYN-RECEIVED state to be reached, the SYN queue is said to be full, thus preventing the target system from establishing other legitimate connections. A full SYN queue therefore results in partially-open TCP connections to IP addresses that either do not exist or are unreachable. In these cases, the connections must reach their timeout before the server can continue fulfilling other requests.	The BIG-IP system includes a feature designed to alleviate SYN flooding. Known as SYN Check, this feature sends information about the flow, in the form of cookies, to the requesting client, so that the system does not need to keep the SYN-RECEIVED state that is normally stored in the connection table for the initiated session. Because the SYN-RECEIVED state is not kept for a connection, the SYN queue cannot be exhausted, and normal TCP communication can continue. The SYN Check feature complements the existing adaptive reaper feature in the BIG-IP system. While the adaptive reaper handles established connection flooding, SYN Check prevents connection flooding altogether. That is, while the adaptive reaper must work overtime to flush connections, the SYN Check feature prevents the SYN queue from becoming full, thus allowing the target system to continue to establish TCP connections.

Attack type	Description	Mitigation
ICMP flood (Smurf)	The ***ICMP flood***, sometimes referred to as a Smurf attack, is an attack based on a method of making a remote network send ICMP Echo replies to a single host. In this attack, a single packet from the attacker goes to an unprotected network's broadcast address. Typically, this causes every machine on that network to answer with a packet sent to the target. The BIG-IP system is hardened against these attacks because it answers only a limited number of ICMP requests per second, and then drops the rest. On the network inside the BIG-IP system, the BIG-IP system ignores directed subnet broadcasts, and does not respond to the broadcast ICMP Echo that a Smurf attacker uses to initiate an attack.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.
UDP flood	The ***UDP flood*** attack is most commonly a distributed Denial of Service attack (DDoS), where multiple remote systems are sending a large flood of UDP packets to the target. The BIG-IP system handles these attacks similarly to the way it handles a SYN flood. If the port is not listening, the BIG-IP system drops the packets. If the port is listening, the reaper removes the false connections.	Setting the UDP idle session timeout to between 5 and 10 seconds reaps these connections quickly without impacting users with slow connections. However, with UDP this might still leave too many open connections, and your situation might require a setting of between 2 and 5 seconds.
UDP fragment	The ***UDP fragment*** attack is based on forcing the system to reassemble huge amounts of UDP data sent as fragmented packets. The goal of this attack is to consume system resources to the point where the system fails. The BIG-IP system does not reassemble these packets, it sends them on to the server if they are for an open UDP service. If these packets are sent with the initial packet opening the connection correctly, then the connection is sent to the back-end server. If the initial packet is not the first packet of the stream, the entire stream is dropped.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.
Ping of Death	The ***Ping of Death*** attack is an attack with ICMP echo packets that are larger than 65535 bytes. As this is the maximum allowed ICMP packet size, this can crash systems that attempt to reassemble the packet. The BIG-IP system is hardened against this type of attack. However, if the attack is against a virtual server with the Any IP feature enabled, then these packets are sent on to the server. It is important that you apply the latest updates to your servers.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.

Attack type	Description	Mitigation
Land	A ***Land*** attack is a SYN packet sent with the source address and port the same as the destination address and port. The BIG-IP system is hardened to resist this attack. The BIG-IP system connection table matches existing connections so that a spoof of this sort is not passed on to the servers. Connections to the BIG-IP system are checked and dropped if spoofed in this manner.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.
Teardrop	A ***Teardrop*** attack is carried out by a program that sends IP fragments to a machine connected to the Internet or a network. The Teardrop attack exploits an overlapping IP fragment problem present in some common operating systems. The problem causes the TCP/IP fragmentation re-assembly code to improperly handle overlapping IP fragments. The BIG-IP system handles these attacks by correctly checking frame alignment and discarding improperly aligned fragments.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.
Data	The BIG-IP system can also offer protection from data attacks to the servers behind the BIG-IP system. The BIG-IP system acts as a port-deny device, preventing many common exploits by simply not passing the attack through to the server.	You do not need to make any changes to the BIG-IP system configuration for this type of attack.
WinNuke	The ***WinNuke*** attack exploits the way certain common operating systems handle data sent to the NetBIOS ports. NetBIOS ports are 135, 136, 137 and 138, using TCP or UDP. The BIG-IP system denies these ports by default.	On the BIG-IP system, do not open these ports unless you are sure your servers have been updated against this attack.
Sub 7	The ***Sub 7*** attack is a Trojan horse that is designed to run on certain common operating systems. This Trojan horse makes it possible the system to be controlled remotely. This Trojan horse listens on port 27374 by default. The BIG-IP system does not allow connections to this port from the outside, so a compromised server cannot be controlled remotely.	Do not open high ports (ports higher than 1024) without explicit knowledge of what applications will be running on these ports.
Back Orifice	A ***Back Orifice*** attack is a Trojan horse that is designed to run on certain common operating systems. This Trojan horse makes it possible the system to be controlled remotely. This Trojan horse listens on UDP port 31337 by default. The BIG-IP system does not allow connections to this port from the outside, so a compromised server cannot be controlled remotely.	Do not open high ports (ports higher than 1024) without explicit knowledge of what will be running on these ports

Task summary for mitigating DoS attacks

There are several tasks you can perform to mitigate Denial of Service attacks.

Configuring adaptive reaping

This procedure configures adaptive reaping. The ***adaptive connection reaper*** closes idle connections when memory usage on the BIG-IP system increases. This feature makes it possible for the BIG-IP system to aggressively reap connections when the system memory utilization reaches the low-water mark, and to stop establishing new connections when the system memory utilization reaches the high-water mark percentage.

If the BIG-IP platform includes an LCD panel, an adaptive reaping event causes the BIG-IP system to display the following message on the LCD panel:

```
Blocking DoS attack
```

The adaptive reaper settings do not apply to SSL connections. However, you can set TCP and UDP connection timeouts that reap idle SSL connections.

1. On the Main tab, click **System › Configuration .**
   The General screen opens.
2. From the Local Traffic menu, choose **General**.
3. In the Properties area of the screen, set the **Reaper High-water Mark** property to `95`.
4. Set the **Reaper Low-water Mark** property to `85`.
5. Click **Update.**

When aggressive mode is activated on the BIG-IP system, the event is marked in the */var/log/ltm* file with messages similar to these examples:

```
tmm tmm[PID]: 011e0002:4: sweeper_update: aggressive mode activated. (117504/138240 pages)
```

```
tmm tmm[PID]: 011e0002:4: sweeper_update: aggressive mode deactivated. (117503/138240 pages)
```

Setting both of the adaptive reaper values to `100` disables this feature.

Setting the TCP and UDP connection timers

You can set the TCP and UDP timers in the profile settings for the TCP profile and the UDP profiles. You should set these timers for the services that you use for your virtual servers. For example, you can set a value of `60` for HTTP connections and `60` for SSL connections.

1. On the Main tab, click **Local Traffic › Profiles.**
2. From the **Protocol** menu, choose TCP or UDP.
3. Click the name of the profile type you want to configure.
4. Set the **Idle Timeout** setting to `60`.
5. Click **Update.**

Applying a rate class to a virtual server

After you create a rate class, you can apply it to the virtual servers in the configuration.

1. On the Main tab, click **Local Traffic › Virtual Servers .**
   The Virtual Server List screen opens.
2. In the **Virtual Server** list, click the virtual server that you want.
3. In the **Configuration** list, click **Advanced.**
4. In the **Rate Class** list, select a rate class.
5. Click **Update.**

The rate class is applied to the virtual server.

Calculating connection limits on the main virtual server

Use this procedure to determine a connection limit.

1. Before you set a connection limit, use the following formula to calculate the connection limit value for the main virtual server:

   ```
   Connection Limit = Approximate Amount of RAM in KB * 0.8.
   ```

   For example, if you have 256 MB of RAM, the calculation is:

   ```
   256,000 * 0.8 = 204800
   ```

   In this case, you set the connection limit to **204800.**

Setting connection limits on the main virtual server

Connection limits determine the maximum number of concurrent connections allowed on a virtual server. In this context, the main virtual server is the virtual server that receives the most traffic to your site.

1. On the Main tab, click **Local Traffic › Virtual Servers .**
   The Virtual Server List screen opens.
2. Click the virtual server that you want to modify.
3. From the **Configuration** list, select **Advanced.**
4. In the **Connection Limit** field, type the number that you calculated for the connection limit.
5. Click **Update** to save the changes.

The virtual server is configured for the specified maximum number of concurrent connections.

Adjusting the SYN Check threshold

You can configure the SYN Check feature to prevent the BIG-IP SYN queue from becoming full during a SYN flood attack. The **SYN Check Activation Threshold** setting indicates the number of new or untrusted TCP connections that can be established before the BIG-IP activates the SYN Cookies authentication method for subsequent TCP connections.

1. On the Main tab, click **System › Configuration .**
2. From the Local Traffic menu, choose General.
3. In the **SYN Check Activation Threshold** field, type the number of connections that you want to define for the threshold.
4. Click **Update**.

If SYN flooding occurs, the BIG-IP system now protects the BIG-IP SYN queue from becoming full.

Contact Support

HAVE A QUESTION?

Support and Sales >

FOLLOW US

ABOUT F5

Corporate Information
Newsroom
Investor Relations
Careers
About AskF5

EDUCATION

Training
Certification
F5 University
Free Online Training

F5 SITES

F5.com
DevCentral
Support Portal
Partner Central
F5 Labs

SUPPORT TASKS

Read Support Policies
Create Service Request
Leave feedback [+]

©2023 F5, Inc. All rights reserved.

Trademarks Policies Privacy California Privacy Do Not Sell My Personal Information Cookie Preferences